

## MODELO DE ENCUESTA INTEGRAL DE CIBERSEGURIDAD

### OWASP SAMM v2 + GQM + PRAGMATIC + Encuesta Multi-Stakeholder

**Versión:** 2.0 | **Fecha:** Enero 2026

**Público:** Organizaciones españolas bajo NIS2, CRA, GDPR, ENS, DORA

**Duración:** 45-60 minutos por respondente | **Respondentes:** 8-13 roles distintos

**Escala:** Ordinal 0-4 con opción "No tengo visibilidad"

### I. INTRODUCCIÓN

Este cuestionario evalúa la **madurez de ciberseguridad de software** de tu organización a través de **120+ preguntas**:

- Basadas en **OWASP SAMM v2** (5 funciones × 3 prácticas × 2 streams)
- Estructuradas con **GQM** (Goal-Question-Metric)
- Evaluables con **PRAGMATIC** (9 criterios de calidad)
- Alineadas a regulación española (**NIS2, CRA, GDPR, ENS, DORA**)
- Diseñadas para **múltiples roles** (evitar sesgos de single perspective)

### II. ESCALA DE RESPUESTA

Para cada pregunta, selecciona la opción que mejor refleje tu situación:

#### Escala 0-4 (Madurez)

| Nivel | Descripción               | Ejemplo                                         | Puntuación |
|-------|---------------------------|-------------------------------------------------|------------|
| 0     | No existe / No se realiza | "Nunca hemos hecho esto"                        | 0 puntos   |
| 1     | Ad-hoc / Inicial          | "Lo hacemos a veces, sin proceso formal"        | 1 punto    |
| 2     | Proceso definido          | "Tenemos un proceso documentado y lo seguimos"  | 2 puntos   |
| 3     | Proceso medido            | "Medimos la efectividad; hay continua mejora"   | 3 puntos   |
| 4     | Optimizado / Automatizado | "Está automatizado y adaptándose continuamente" | 4 puntos   |

#### Opción especial

- N/A: "No tengo suficiente visibilidad para responder"
- Marca esta opción si no tienes datos o acceso
- Indicará brecha de comunicación entre roles (necesita investigación)

### III. ESTRUCTURA DE MÓDULOS (11 Módulos)

La encuesta se divide en **11 módulos temáticos**, agrupables por **SAMM Function**:

MÓDULO 1: Datos demográficos (5 min)

└ Rol, departamento, nivel de autoridad

MÓDULO 2: Gobernanza (10 min) – SAMM: Governance

└ Estrategia AppSec, KPIs, comunicación, roles

MÓDULO 3: Diseño (10 min) – SAMM: Design

└ Threat modeling, STRIDE, arquitectura

MÓDULO 4: Implementación (12 min) – SAMM: Implementation

└ SAST, SCA, CI/CD gates, secrets management

MÓDULO 5: Verificación (10 min) – SAMM: Verification

└ Test coverage, DAST, pentesting, ejercicios

MÓDULO 6: Operaciones (12 min) – SAMM: Operations

└ MTTD, MTTR, patch, incident response

MÓDULO 7: Análisis de Vulnerabilidades (10 min) – SAMM Vuln

└ Escaneo, priorización, cierre de vulns

MÓDULO 8: SIEM y Operaciones de Seguridad (10 min) – SAMM SIEM

└ Cobertura logs, alertas, detección, timeliness

MÓDULO 9: Capacitación y Conciencia (10 min) – SAMM Training

└ Formación, phishing simulations, comportamiento

MÓDULO 10: Cumplimiento Normativo (7 min) – Transversal

└ NIS2, CRA, GDPR, ENS, DORA compliance

MÓDULO 11: Meta-preguntas (3 min) – Metría

└ Confianza en respuestas, facilidad de encuesta

### IV. MÓDULO 1: DATOS DEMOGRÁFICOS (5 min)

**Pregunta 1.1** — Tu rol en la organización

¿Cuál es tu rol principal?

( ) CISO / Director de Seguridad

( ) Arquitecto de Software / Aplicaciones

( ) Developer / Ingeniero de Software

( ) DevSecOps / Ingeniero de Implementación

( ) QA / Tester / Analista de Calidad

( ) Responsable SIEM / SOC / Operaciones

( ) Compliance / Audit / GRC

( ) Otro: \_\_\_\_\_

**Pregunta 1.2** — Departamento

¿Cuál es tu departamento?

- ☐ Seguridad de Información
- ☐ Desarrollo de Software
- ☐ Operaciones / Infrastructure
- ☐ Calidad / QA
- ☐ Compliance / Legal
- ☐ Ejecutiva (Board-level)
- ☐ Otro: \_\_\_\_\_

### **Pregunta 1.3 — Nivel de autoridad**

¿Cuál es tu nivel de decisión?

- ☐ Ejecutor (hace el trabajo técnico)
- ☐ Supervisor (gestiona equipo, ejecutores)
- ☐ Manager (toma decisiones tácticas)
- ☐ Director/VP (toma decisiones estratégicas)

### **Pregunta 1.4 — Antigüedad**

¿Cuánto tiempo llevas en tu rol actual?

- ☐ < 6 meses
- ☐ 6-12 meses
- ☐ 1-2 años
- ☐ 2-5 años
- ☐ > 5 años

### **Pregunta 1.5 — Sector/Industria**

¿En qué sector opera tu organización?

- ☐ Tecnología / Software
- ☐ Financiero / Bancos
- ☐ Telecom
- ☐ Energía / Utilidades
- ☐ Sanidad
- ☐ Administración Pública
- ☐ Retail / E-commerce
- ☐ Manufactura
- ☐ Educación
- ☐ Otro: \_\_\_\_\_

## **V. MÓDULO 2: GOBERNANZA (10 min)**

### **GOV.1: Estrategia y Dirección**

#### **Pregunta 2.1 — Estrategia de seguridad de software formalizada**

¿Existe una estrategia plurianual documentada de seguridad de software (AppSec)?

- 0 ☐ No existe estrategia formal
- 1 ☐ Existe borradores/documentos informales
- 2 ☐ Existe documento de estrategia formal, pero desactualizado (>12 meses)
- 3 ☐ Existe estrategia formal, actualizada, revisada anualmente
- 4 ☐ Estrategia formal, actualizada, revisada 2+ veces/año, comunicada activamente
- N ☐ No tengo visibilidad

## **Pregunta 2.2 — Comunicación de la estrategia**

¿Con qué frecuencia se comunica la estrategia AppSec a stakeholders?

- 0 ☐ Nunca se comunica
- 1 ☐ Comunicada sólo a CISO/ejecutivos
- 2 ☐ Comunicada 1-2 veces/año a equipos
- 3 ☐ Comunicada 2-4 veces/año; accesible en portal
- 4 ☐ Comunicada cada trimestre; discusiones mensuales; parte de OKRs
- N ☐ No tengo visibilidad

## **Pregunta 2.3 — KPIs de seguridad de software**

¿Existen KPIs (métricas clave) definidas para medir éxito de la estrategia AppSec?

- 0 ☐ No hay KPIs definidas
- 1 ☐ Existen 1-2 KPIs informales
- 2 ☐ Existen 3-4 KPIs documentadas, algunas rastreadas
- 3 ☐ Existen 5-7 KPIs formales, rastreadas mensualmente
- 4 ☐ >7 KPIs formales, rastreadas semanalmente, con dashboards automáticos
- N ☐ No tengo visibilidad

## **GOV.2: Gestión de Políticas**

### **Pregunta 2.4 — Políticas de seguridad de software**

¿Existen políticas de seguridad de software documentadas y comunicadas?

- 0 ☐ No hay políticas de AppSec
- 1 ☐ Políticas informales o en desarrollo
- 2 ☐ Políticas documentadas, disponibles a equipo
- 3 ☐ Políticas documentadas, formales, versioned, con revisión anual
- 4 ☐ Políticas formales, versioned, revisadas 2+ veces/año, automatizadas en herramientas
- N ☐ No tengo visibilidad

### **Pregunta 2.5 — Cumplimiento de políticas**

¿Con qué frecuencia se verifica el cumplimiento de políticas de AppSec?

- 0 ☐ Nunca se verifica
- 1 ☐ Ad-hoc, cuando hay incidentes
- 2 ☐ Anualmente, por auditoría
- 3 ☐ Trimestralmente, con reportes
- 4 ☐ Mensualmente o continuo, automatizado
- N ☐ No tengo visibilidad

### GOV.3: Roles y Responsabilidades

#### Pregunta 2.6 — Asignación de responsabilidades

¿Están claramente definidas las responsabilidades de seguridad por rol?

- 0 ☐ No hay definición de roles
- 1 ☐ Roles existen pero son informales
- 2 ☐ Roles documentados en organigramas
- 3 ☐ Roles documentados con RACI matrix; comunicados a equipos
- 4 ☐ RACI formal, parte de contrataciones, evaluaciones de desempeño, SLAs
- N ☐ No tengo visibilidad

## VI. MÓDULO 3: DISEÑO (10 min)

### DES.1: Threat Modeling

#### Pregunta 3.1 — Cobertura de threat modeling

¿Qué % de aplicaciones críticas tienen threat model documentado?

- 0 ☐ 0% (no hay threat models)
- 1 ☐ 1-20% (algunos iniciados)
- 2 ☐ 21-50% (aproximadamente mitad)
- 3 ☐ 51-80% (la mayoría)
- 4 ☐ 81-100% (cobertura completa)
- N ☐ No tengo visibilidad

#### Pregunta 3.2 — Metodología de threat modeling

¿Qué metodología se usa para threat modeling?

- 0 ☐ Ninguna (ad-hoc o inexistente)
- 1 ☐ Informal (conversaciones sin estructura)
- 2 ☐ Usa STRIDE, PASTA o similar; documentación básica
- 3 ☐ Usa framework formal; documentación estándar; reviews internos
- 4 ☐ Framework formal; reviews con pares externos; integrado en SDL
- N ☐ No tengo visibilidad

#### Pregunta 3.3 — Actualización de threat models

¿Con qué frecuencia se actualizan los threat models?

- 0 ☐ Nunca se actualizan
- 1 ☐ Se actualizan solo cuando hay cambios mayores (>1 año)
- 2 ☐ Se actualizan anualmente
- 3 ☐ Se actualizan 2+ veces/año o cuando hay cambios arquitectónicos
- 4 ☐ Se actualizan continuamente; versionado en control de código
- N ☐ No tengo visibilidad

## VII. MÓDULO 4: IMPLEMENTACIÓN (12 min)

### IMP.1: Integración de seguridad en build

#### Pregunta 4.1 — SAST (Static Application Security Testing) en CI/CD

¿Qué % de aplicaciones tienen SAST integrado en CI/CD?

- 0 ☐ 0% (no hay SAST)
- 1 ☐ 1-25% (algunos proyectos)
- 2 ☐ 26-50% (aproximadamente mitad)
- 3 ☐ 51-80% (la mayoría)
- 4 ☐ 81-100% (cobertura completa; bloqueadores activos)
- N ☐ No tengo visibilidad

#### **Pregunta 4.2 — SCA (Software Composition Analysis)**

¿Se analiza composición de software (dependencias de terceros) en builds?

- 0 ☐ No (sin SCA)
- 1 ☐ Raramente (manual, no automatizado)
- 2 ☐ Sí, en algunas aplicaciones
- 3 ☐ Sí, en la mayoría de aplicaciones
- 4 ☐ Sí, en 100%; automatizado; bloqueadores para vulns críticas
- N ☐ No tengo visibilidad

### **IMP.2: Secrets Management**

#### **Pregunta 4.3 — Gestión de credenciales**

¿Cómo se manejan las credenciales (API keys, DB passwords, certs)?

- 0 ☐ Hardcoded en código o archivos de config
- 1 ☐ Variables de entorno (sin gestión centralizada)
- 2 ☐ Vault/Manager centralizado; pero no enforced en todos los proyectos
- 3 ☐ Vault/Manager enforced; scans para detectar secrets en repos
- 4 ☐ Vault/Manager enforced; scans automatizados; rotación automática
- N ☐ No tengo visibilidad

## **VIII. MÓDULO 5: VERIFICACIÓN (10 min)**

### **VER.1: Pruebas de Seguridad**

#### **Pregunta 5.1 — Cobertura de pruebas de seguridad**

¿Qué % de requisitos de seguridad tienen test cases?

- 0 ☐ 0% (no hay tests de seguridad)
- 1 ☐ 1-25% (algunos requisitos)
- 2 ☐ 26-50% (aproximadamente mitad)
- 3 ☐ 51-80% (la mayoría)
- 4 ☐ 81-100% (cobertura completa)
- N ☐ No tengo visibilidad

#### **Pregunta 5.2 — Penetration Testing**

¿Con qué frecuencia se realizan pentests a apps críticas?

- 0 ☐ Nunca
- 1 ☐ A demanda (cuando hay presupuesto)
- 2 ☐ 1 vez/año
- 3 ☐ 2 veces/año
- 4 ☐ 3+ veces/año o continuous penetration testing
- N ☐ No tengo visibilidad

## IX. MÓDULO 6: OPERACIONES (12 min)

### OPS.1: Detección y Respuesta

#### Pregunta 6.1 — MTDD (Mean Time To Detect)

¿Cuál es el tiempo promedio de detección de incidentes (MTDD)?

- 0 ☐ >1 semana (muy lento)
- 1 ☐ 2-7 días
- 2 ☐ 1-2 días
- 3 ☐ 4-24 horas
- 4 ☐ <4 horas (excelente)
- N ☐ No tengo visibilidad

#### Pregunta 6.2 — MTTR (Mean Time To Remediate)

¿Cuál es el tiempo promedio de remediación para vulnerabilidades críticas?

- 0 ☐ >1 mes
- 1 ☐ 15-30 días
- 2 ☐ 8-14 días
- 3 ☐ 2-7 días
- 4 ☐ <24 horas
- N ☐ No tengo visibilidad

#### Pregunta 6.3 — Cumplimiento de patching

¿Qué % de sistemas críticos se parchean dentro del SLA (ej: 24h para crítico)?

- 0 ☐ <50%
- 1 ☐ 50-70%
- 2 ☐ 71-85%
- 3 ☐ 86-95%
- 4 ☐ >95%
- N ☐ No tengo visibilidad

## X. MÓDULO 7: ANÁLISIS DE VULNERABILIDADES (10 min)

#### Pregunta 7.1 — Cobertura de escaneo

¿Qué % de sistemas/apps se escanean en busca de vulnerabilidades cada mes?

- 0 ☐ 0% (no hay escaneo)
- 1 ☐ 1-30%
- 2 ☐ 31-60%
- 3 ☐ 61-90%
- 4 ☐ >90%
- N ☐ No tengo visibilidad

### Pregunta 7.2 — Priorización de vulns (CVSS vs EPSS)

¿Cómo se priorizan vulnerabilidades?

- 0 ☐ No hay priorización formal
- 1 ☐ Solo CVSS score
- 2 ☐ CVSS + algún contexto manual
- 3 ☐ CVSS + contexto + algunos datos EPSS
- 4 ☐ EPSS + contexto de negocio + inteligencia de amenazas
- N ☐ No tengo visibilidad

### Pregunta 7.3 — Cierre de vulnerabilidades críticas

¿Qué % de vulns críticas se cierran dentro de 30 días?

- 0 ☐ <50%
- 1 ☐ 50-70%
- 2 ☐ 71-85%
- 3 ☐ 86-95%
- 4 ☐ >95%
- N ☐ No tengo visibilidad

## XI. MÓDULO 8: SIEM Y OPERACIONES (10 min)

### Pregunta 8.1 — Cobertura SIEM

¿Qué % de tipos de fuentes de datos definidas están activamente en SIEM?

- 0 ☐ 0-30% (cobertura muy baja)
- 1 ☐ 31-50%
- 2 ☐ 51-70%
- 3 ☐ 71-90%
- 4 ☐ >90%
- N ☐ No tengo visibilidad

### Pregunta 8.2 — Calidad de alertas (False Positive Rate)

¿Cuál es la tasa de falsos positivos (% de alertas que no son incidentes reales)?

- 0 ☐ >70% (muchas falsas alarmas)
- 1 ☐ 50-70%
- 2 ☐ 40-50%
- 3 ☐ 20-40%
- 4 ☐ <20% (excelente)
- N ☐ No tengo visibilidad



## XII. MÓDULO 9: CAPACITACIÓN Y CONCIENCIA (10 min)

### Pregunta 9.1 — Cobertura de formación anual

¿Qué % de empleados completó formación de ciberseguridad en el último año?

- 0 ☐ <50%
- 1 ☐ 50-70%
- 2 ☐ 71-85%
- 3 ☐ 86-95%
- 4 ☐ >95%
- N ☐ No tengo visibilidad

### Pregunta 9.2 — Phishing click-rate

¿Cuál es la tasa de clic en simulaciones de phishing (% que cliclean)?

- 0 ☐ >20% (muy vulnerable)
- 1 ☐ 15-20%
- 2 ☐ 10-15%
- 3 ☐ 5-10%
- 4 ☐ <5% (excelente)
- N ☐ No tengo visibilidad

### Pregunta 9.3 — Phishing report rate

¿Cuál es la tasa de reporte en simulaciones de phishing (% que reportan)?

- 0 ☐ <20% (bajo engagement)
- 1 ☐ 20-40%
- 2 ☐ 41-60%
- 3 ☐ 61-80%
- 4 ☐ >80% (muy alto)
- N ☐ No tengo visibilidad

## XIII. MÓDULO 10: CUMPLIMIENTO NORMATIVO (7 min)

### Pregunta 10.1 — Alineación con NIS2

¿En qué medida está alineada tu organización con requisitos NIS2?

- 0 ☐ No hay conocimiento de NIS2
- 1 ☐ Conocimiento inicial; poco avance
- 2 ☐ Algunas medidas implementadas
- 3 ☐ Mayoría de medidas implementadas
- 4 ☐ Totalmente alineada; con auditoría confirmada
- N ☐ No tengo visibilidad

### Pregunta 10.2 — Alineación con CRA

¿En qué medida está alineada tu organización con requisitos CRA (Secure by Design)?

- 0 ☐ No hay conocimiento de CRA
- 1 ☐ Conocimiento inicial; poco avance
- 2 ☐ Algunas medidas implementadas
- 3 ☐ Mayoría de medidas implementadas
- 4 ☐ Totalmente alineada; con auditoría confirmada
- N ☐ No tengo visibilidad

### **Pregunta 10.3 — Alineación con GDPR**

¿En qué medida está alineada tu organización con Privacy by Design (GDPR Art. 25)?

- 0 ☐ No hay medidas de privacy
- 1 ☐ Medidas mínimas o ad-hoc
- 2 ☐ Medidas documentadas pero parcial
- 3 ☐ Mayoría de medidas implementadas
- 4 ☐ Totalmente integrado; DPA involucrado; auditoría confirmada
- N ☐ No tengo visibilidad

## **XIV. MÓDULO 11: META-PREGUNTAS (3 min)**

### **Pregunta 11.1 — Confianza en las respuestas**

¿Con qué confianza respondiste esta encuesta?

- 0 ☐ Muy baja confianza (adivinando en muchas)
- 1 ☐ Baja confianza (muchas estimaciones)
- 2 ☐ Media confianza (basadas en conocimiento aproximado)
- 3 ☐ Alta confianza (información verificada)
- 4 ☐ Muy alta confianza (datos verificados, auditoría)

### **Pregunta 11.2 — Facilidad de encuesta**

¿Cuán fácil fue responder esta encuesta?

- 0 ☐ Muy difícil (confuso, preguntas complicadas)
- 1 ☐ Difícil (necesité ayuda)
- 2 ☐ Neutral (algunas preguntas claras, otras no)
- 3 ☐ Fácil (mayormente claro)
- 4 ☐ Muy fácil (totalmente claro)

### **Pregunta 11.3 — Comentarios finales**

¿Tienes comentarios adicionales sobre la encuesta, ciberseguridad en tu org, o recomendaciones?

[Texto libre] \_\_\_\_\_

## XV. RESUMEN DE ESTRUCTURA

| Módulo              | Preguntas | Tiempo (min) | Dominio SAMM      |
|---------------------|-----------|--------------|-------------------|
| 1. Demográficos     | 5         | 5            | Meta              |
| 2. Gobernanza       | 6         | 10           | Governance        |
| 3. Diseño           | 3         | 10           | Design            |
| 4. Implementación   | 3         | 12           | Implementation    |
| 5. Verificación     | 2         | 10           | Verification      |
| 6. Operaciones      | 3         | 12           | Operations        |
| 7. Vulnerabilidades | 3         | 10           | Vulnerabilities   |
| 8. SIEM             | 2         | 10           | Operations (SIEM) |
| 9. Capacitación     | 3         | 10           | Training          |
| 10. Cumplimiento    | 3         | 7            | Transversal       |
| 11. Meta            | 3         | 3            | Metría            |
| TOTAL               | 39        | 45-60        | 8 dominios        |

## XVI. NOTAS PARA ADMINISTRADOR

1. Multirol: Distribuir encuesta a 8-13 respondentes de diferentes roles para triangulación
2. Anonimato opcional: Permitir anonimato si es necesario (riesgo: menos accountability)
3. Seguimiento: Generar reporte con discrepancias por rol (falta de visibilidad)
4. Validación: Correlacionar respuestas con datos técnicos (SIEM, scanner logs, etc.)
5. Sesión de calibración: 90 min pre-encuesta para explicar criterios de scoring